

MÓDULO 2
Arquitecturas de seguridad
y técnicas
Ciberseguridad

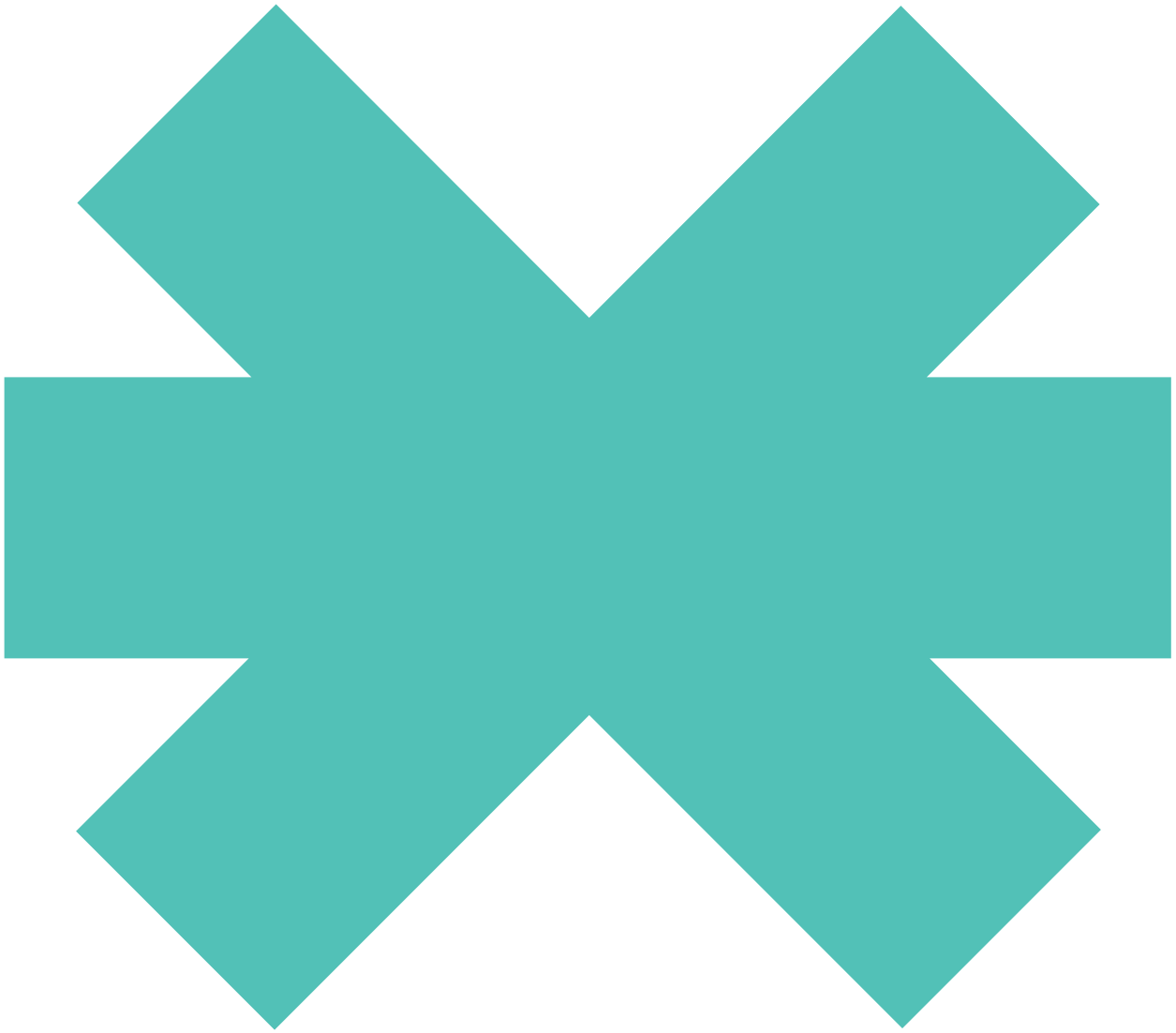
1

Arquitectura de seguridad y su aplicación



New
Technology
School

Tokio.



1 Arquitectura de seguridad y su aplicación

Sumario

1.1	Introducción a las arquitecturas de seguridad	112
1.2	¿A qué departamentos de una compañía se aplica la seguridad?	113
1.3	¿Cómo definir una arquitectura de seguridad?	114

1.1 Introducción a las arquitecturas de seguridad

Para poder proteger los datos de cualquier organización o compañía, resulta imprescindible contar con una correcta arquitectura de seguridad que haya sido diseñada teniendo en cuenta la segmentación de redes en subredes, así como los perfiles de acceso a cada una de ellas.

Además, en caso de contemplarse una posible conexión desde el exterior o la comunicación con servidores de la organización, resultará fundamental establecer una DMZ (*Demilitarized Zone*) entre la red interna y la externa... Ahora bien, ¿qué es una DMZ?

Una **DMZ** o **zona desmilitarizada** es una zona de intercambio de comunicaciones segura que se sitúa entre la red interna y la externa y donde se establecen los servidores de correo de una organización, los servidores VPN, etc. Por tanto, se trata de una red intermedia de computadores que se ubica entre la red interna privada y otra externa no confiable, como internet. Su finalidad consiste en reforzar la seguridad de una red creando una capa adicional de protección entre los recursos internos y los posibles ataques externos. En este sentido, recurre a *firewalls* y a reglas de seguridad que controlan el tráfico que ingresa y sale de la red interna. Así, en una configuración típica, se colocan en la DMZ aquellos servidores que sean accesibles públicamente, entre ellos, los servidores web, de correo electrónico o de aplicaciones.

La configuración de la DMZ permite que los servidores situados en ella sean accesibles desde el exterior y, al mismo tiempo, que dispongan de un acceso limitado a la red interna. De este modo, actúa como una barrera protectora que filtra y controla el tráfico de la red entrante y saliente. En el caso de que se detecte una actividad sospechosa o maliciosa en la DMZ, se evita su propagación hacia la red interna para prevenir ataques y proteger los recursos.

1.2 ¿A qué departamentos de una compañía se aplica la seguridad?

Resulta crucial que la seguridad de una compañía no resida únicamente en una zona de la organización, sino que se contemple en todos sus ámbitos. Este planteamiento puede llegar a ser confuso, ya que, en numerosas ocasiones, se considera que el departamento de sistemas o el de seguridad deberían ser los únicos encargados de este aspecto dentro de la empresa; no obstante, todos los empleados y las empleadas son responsables de la seguridad, pues todos representan un potencial objetivo de ataque.

Como suele afirmarse, el eslabón más débil de una cadena es aquel que se va a romper antes, de manera que también es el que determina su fortaleza. Resulta inútil invertir en los mejores *firewalls* o *softwares* de antivirus, detección de amenazas, SIEM (*Security Information and Event Management*), etc. si, posteriormente, cualquier empleado va a abrir un correo con *malware*, *phishing*, etc.

También es cierto que toda compañía cuenta con departamentos más susceptibles de convertirse en objeto de ataques, entre ellos, el de sistemas, pues alberga la información digital de toda la compañía; el de finanzas, que puede sufrir ataques económicos donde se traten de extraer cantidades de dinero mediante estafas; o el más vulnerable de todos ellos, el directivo, pues dispone de las autorizaciones requeridas para realizar transacciones económicas, acuerdos de proveedores, etc.

1.3 ¿Cómo definir una arquitectura de seguridad?

En primer lugar, es importante definir qué es una arquitectura segura, ya que si no delimitamos claramente el concepto, resultará más complejo identificar qué elementos y necesidades de una compañía deben contemplarse para diseñar una correcta arquitectura de seguridad.

Denominamos **arquitectura segura** al conjunto de componentes de IT integrados en una determinada red que ha sido diseñada atendiendo a la seguridad, a la interconectividad de sus elementos y a las diferentes subredes que comprende.

Asimismo, cuando se habla de arquitecturas de seguridad es vital tener en cuenta los siguientes principios de seguridad:

- **Trust but Verify (Confía pero verifica):** Este principio se basa en la idea de que aunque se confíe en un sistema o persona, es esencial realizar verificaciones para asegurar que todo funcione como debería. Es fundamental revisar las configuraciones y controles de un sistema para garantizar que estén establecidos como deberían. Esto puede incluir la revisión de políticas de seguridad, autenticaciones, autorizaciones y otros aspectos críticos.
- **Zero Trust (Confianza cero):** Las arquitecturas Zero Trust significan que no se confía por defecto en ningún usuario o sistema, incluso aunque se encuentre en la red corporativa. Todo debe ser verificado antes de conceder acceso. Esto a menudo implica el uso de autenticación multifactor, aplicación de políticas estrictas y monitoreo constante.
- **Defense in Depth (Defensa en profundidad):** La defensa en profundidad consiste en aplicar diversas capas de seguridad para proteger un sistema. Si una capa falla, las capas adicionales actuarán como respaldo. Esto implica que los sistemas de seguridad trabajen en conjunto para proporcionar una protección robusta.
- **Security through Obscurity (Seguridad por oscuridad):** Este concepto implica ocultar o enmascarar recursos, procesos y servicios para dificultar que un atacante los encuentre. Aunque pueda añadir una capa extra de seguridad, es importante destacar, que la seguridad por oscuridad no se considera una práctica robusta por sí sola.

Finalmente resulta esencial establecer los diferentes elementos que contendrá nuestra red, entre ellos, *switches*, *routers*, *firewalls*, etc. A continuación, nos referiremos a los más importantes.



Figura 1. *Switch* de red. Fuente: Freepik.com

Segmentación de redes

Para evitar el uso indebido de la infraestructura de red de una compañía, resulta imprescindible contar con una correcta segmentación de redes; además, en caso de sufrir un ataque, dicha segmentación contribuirá a prevenir su expansión o a que este sea exitoso. Las empresas presentan zonas más críticas que otras y, por esta razón, para evitar juntar departamentos entre sí, la red debe encontrarse segmentada.

Segmentar la red nos permite **implementar políticas de seguridad más específicas**, así como **controlar el flujo de tráfico entre segmentos**, previniendo la propagación de ataques y limitando el acceso no autorizado a los recursos sensibles. Del mismo modo, si una parte de la red experimenta una falla, la segmentación evita que esta afecte a toda la red, ya que cada segmento es **independiente** y puede funcionar de manera **aislada**, lo que también mejora el rendimiento al reducir el tamaño y la congestión de la red.

Firewalls

Se trata de dispositivos de control de red que, por norma general, se sitúan entre dos redes (pueden ubicarse entre la red interna de una compañía e internet) y cuya principal función consiste en **filtrar las diferentes conexiones entre redes**, pudiendo discriminar por puertos, servicios y protocolos.

El tráfico se controla en base a **reglas de seguridad preestablecidas**; así, por ejemplo, pueden permitir conexiones salientes para navegar por internet y, a la vez, bloquear ciertos tipos de tráfico no autorizado. Mediante este control, el *firewall* analiza cada paquete de datos que atraviesa la red y aplica las reglas de filtrado que hayan sido establecidas, decidiendo si se permite su paso o no. Normalmente, estas reglas suelen fundamentarse en direcciones IP, puertos, protocolos o en cualquier otro criterio relevante.

Cabe destacar que los *firewalls* pueden implementarse tanto en forma de *hardware* como de *software*, resultando común, asimismo, utilizar *firewalls* tanto a nivel de red como de *host*.

Autenticación y control de acceso

Denominamos **autenticación** al proceso mediante el cual se verifica la identidad de un usuario o dispositivo que intenta acceder a un sistema o recurso. Una vez autenticado correctamente, el **control de acceso** se encarga de definir y aplicar las políticas que determinan los recursos o acciones específicas que están permitidas para dicho usuario. Estas medidas conjuntas están destinadas a establecer **controles de movimiento lateral entre las subredes de una compañía**. Contar con unos controles de acceso y autenticación correctos evitará el uso no legítimo de muchos sistemas de la compañía, impidiendo que pueda proliferar un ataque.



Figura 2. Inicio de sesión. Fuente: Freepik.com

Entre los distintos métodos de autenticación, podemos mencionar:

- **Contraseñas.** Se trata del método más común. La combinación de nombre de usuario y contraseña debe incluirse en el registro del sistema.
- **Tokens.** Dispositivos físicos o aplicaciones móviles dirigidos a generar códigos únicos que deben ingresarse junto con la contraseña para autenticar al usuario.
- **Tarjetas inteligentes.** Disponen de chips integrados y pueden requerir una contraseña o un PIN para autenticar al usuario.
- **Biometría.** Los sistemas biométricos, como huellas dactilares, reconocimiento facial o escaneo del iris, también permiten autenticar al usuario o usuaria.

Veamos los métodos más usados de cara al control de acceso:

- **Listas de control de acceso (ACL).** Se trata de listas donde se especifica qué usuarios/as o grupos disponen de permiso para acceder a determinados recursos.
- **Roles y permisos.** Se asignan roles específicos a los usuarios y se definen los permisos asociados a cada uno de ellos.
- **Autenticación de dos factores (2FA) o multifactor (MFA).** Además de la autenticación inicial, se requiere un segundo factor, como un código o una huella digital.

Encriptación

Como hemos visto en el módulo anterior, para evitar un posible ataque dentro de las comunicaciones de una compañía o entre una web y el servidor, resulta imprescindible que los datagramas viajen cifrados por toda la red, ya que es muy sencillo interceptar un paquete de datos y, en caso de no haber sido cifrados correctamente, podrían leerse sin dificultad, pudiendo contener información relativa a la facturación, datos sensibles de los usuarios y las usuarias, sus perfiles y contraseñas, etc.

Prevención de intrusiones

Para monitorear y analizar el tráfico de la red en busca de actividades sospechosas o maliciosas, se deben implementar sistemas de prevención (IPS) y de detección (IDS) de intrusiones capaces de detectarlas y bloquearlas, así como de enviar alertas al personal de seguridad.

Los **IDS** monitorean y analizan el tráfico de la red buscando actividades anómalas o patrones de comportamiento que puedan indicar un ataque o una intrusión. En este sentido, analizan los eventos y generan alertas para informar de posibles amenazas, de manera que su principal función es la **prevención temprana de intrusiones y actividades sospechosas**.

Los **IPS**, por su parte, van un paso más allá, pues no solo detectan las intrusiones, sino que también despliegan medidas activas para prevenirlas o bloquearlas. Así, cuando el IPS detecta una actividad maliciosa, puede iniciar **acciones automatizadas** para bloquear el tráfico de la red o adoptar **medidas correctivas** para evitar que la intrusión surta efecto.

Actualizaciones y parches

Todos los sistemas que se implementan en una red carecen de eficacia si no se actualizan con periodicidad. Dado que es muy posible que surjan vulnerabilidades ligadas a las tecnologías de defensa que utiliza nuestra red, si estas no se parchean o actualizan a tiempo, podrían convertirse en aliadas de los ciberatacantes.